

Bug report – “tests” branch

CareO care home management · 5 October 2026 · 68 issues found by automated tests · 66 fixed on this branch · 1 open

Summary

Testing on this branch ran in four passes: database security tests, application/unit tests, a Playwright suite covering every feature of the resident profile, and a last pass over the remaining features (full medication, incident and hospital passport forms, handover, action plans, CareO audit, staff, settings, and a sweep that opens every main page as each staff role). Each fixed bug has an automated test that failed before the fix and passes now. The tests are kept as regression tests and are still named `BUG: ...` after the defect they guard against. Open items (D13) are kept as expected-failure tests.

Pass	Critical	High	Medium	Low	Total
A · Security & data isolation (database / server actions)	8	5	2	–	15
B · Application flows (end-to-end and unit tests)	–	7	9	6	22
C · Resident profile (Playwright suite)	1	11	2	4	18
D · Remaining features (medication, incidents, handover, audits, staff)	–	6	6	1	13
All	9	29	19	11	68

Automated test results after the fixes

Suite	Command	Passed	Failed	Notes
Unit (Vitest)	<code>npm run test:unit</code>	302	0	Includes every tests/unit BUG regression.
Database security (Vitest)	<code>npm run test:db</code>	109	0	Against local Supabase with all four new migrations applied. Includes 2 expected failures (it.fails) for open item D13 and the staff_trainings access tests.
End-to-end (Playwright)	<code>npx playwright test</code>	239	0	One clean full run on the final code (16.2 min), including the staff training records, owner-free witness lists and the dashboard incidents card.

Setting up for manual testing

1. Start the local stack: `npx supabase start`, then apply migrations with `npx supabase db reset` (Or `npx supabase migration up`). Four migrations are new on this branch: `20261005120000_security_hardening.sql`, `20261005150000_resident_record_integrity.sql`, `20261005170000_handover_delete_policies.sql` and `20261005180000_staff_trainings.sql`.
2. Run the app against local Supabase: `npm run dev` with the values from `.env.test` (the Playwright config does this automatically on port 3100).
3. Test accounts: running any e2e spec (e.g. `npx playwright test tests/e2e/journeys.spec.ts`) creates two organisations, three care homes, a resident per home and one user per role. Their emails are written to `tests/e2e/.auth/world.json`; the password for all of them is `Test-Password-123!`.
4. For the time-zone bugs (C9, C13, C14, D2–D4, D6) change the computer's time zone to one ahead of the UK (e.g. India) before testing, or test between March and October; everything should still show UK time and the dates you picked.

Running the automated tests

- Unit: `npm run test:unit` · Database security: `npm run test:db` (needs local Supabase)
- End-to-end: `npm run test:e2e`; only the resident profile: `npx playwright test tests/e2e/resident-`
- HTML report with traces and screenshots of any failure: `npx playwright show-report`

Manual vs automated testing

The Playwright tests do what a tester does (open pages, click, type, submit) in a real Chrome browser against the real app and local database. They also check the saved data directly in the database, which a manual tester can't easily see. They don't replace a person, because they only check what someone wrote them to check.

Playwright covers well	Still needs a person
Same steps every time, all 239 tests in about 16 minutes	Does the page look right and make sense to care staff?
Checks what was saved in the database, not only what is shown	Real devices: tablets and phones, touch, slow Wi-Fi
Role and organisation boundaries (8 roles, 2 organisations)	PDF/print output, real emails arriving, real NHS data
Time-zone and edge cases that are hard to set up by hand	Things nobody thought to test: exploratory use
Catches regressions on every change	Final acceptance before release

Suggested use: run the automated suites on every change, and use the manual checks in this report for release sign-off and anything visual.

Bug register

ID	Severity	Area	Bug
A · Security & data isolation (database / server actions)			
A1	Critical	Tenancy	A nurse could move themselves into another organisation and read its residents
A2	Critical	Tenancy	A care assistant could switch to another care home in the same organisation
A3	Critical	Sign-up	A brand-new self sign-up could attach itself to any organisation
A4	Critical	Sign-up	Agency self sign-up could pick an elevated role via user metadata
A5	High	Roles	A manager could promote a colleague to owner (above their own level)
A6	High	Roles	Kitchen staff could read clinical records (medications, DNACPR, notes)
A7	High	Rota	A nurse could self-approve as 'manager approved nurse' to gain rota management
A8	Critical	Rota	Managers could create / manage rotas and temporary staff for another organisation's team
A9	Critical	Server actions	Anonymous callers could invoke Server Actions by passing someone else's actorId
A10	High	Staff	Cross-organisation staff changes (approve rota manager, toggle RQIA login)
A11	Critical	Email	Anonymous callers could send email from care@careo.uk; invite HTML was injectable
A12	Critical	Tenancy	Tenant isolation gaps on data tables (cross-organisation SELECT / UPDATE / DELETE)
A13	High	Tenancy	Non-owner staff in care home A1 could read records of care home A2 in the same organisation
A14	Medium	Kitchen	Diet notifications: sent on no-op saves, and visible to other care homes' kitchens
A15	Medium	Visitors	External visitor login logs were visible across organisations

ID	Severity	Area	Bug
B · Application flows (end-to-end and unit tests)			
B1	High	Auth	Anonymous visitors were not redirected away from /settings pages
B2	Medium	Auth	Kitchen staff could reach blocked pages via browser Back
B3	Low	Accessibility	Login form labels were not associated with their inputs
B4	High	API	PDF API routes produced resident documents without a session
B5	High	Invitations	Accepting an invitation / agency onboarding wrote role and organisation from the browser
B6	Medium	Members	Removing a member from the organisation failed
B7	Medium	Rota	Shift swaps listed other teams' shifts and draft rotas
B8	Low	Onboarding	Care home form overwrote the name the user had typed
B9	Medium	Audit	Action-plan queries failed (400) on tables without assigned_to_email
B10	Medium	Medication	Nearest medication round did not wrap past midnight (23:50 picked 20:00)
B11	Low	Incidents	Incident time parsing accepted minutes like 10:99
B12	Low	Dates	'30 days ago' shown as '2 days' (weeks wrapped modulo 4)
B13	Medium	Food & fluid	Refused drinks (0 ml) counted as intake; 'Cup of tea' not recognised as fluid
B14	Medium	Privacy	getAge logged residents' dates of birth to the browser console
B15	High	Uploads	File upload check allowed scripts / HTML / SVG
B16	High	Residents	Resident form accepted invalid DOB, future DOB, admission before birth, invalid NHS numbers, blank names
B17	High	Medication	Medication form accepted non-numeric strength, invalid/duplicate times, CD without schedule, negative stock
B18	Medium	Auth	New password only required 8 characters (policy says capital, number, special)
B19	High	Medication	Blood sugar accepted text; insulin could be recorded without site or second signature
B20	Low	Residents	getAge returned NaN for an invalid date of birth
B21	Low	Rota	Rota generator allows back-to-back day + night shifts (<i>By design</i>)
B22	Medium	Auth	Login could hang on 'Redirecting...' after a correct password
C · Resident profile (Playwright suite)			
C1	High	Progress notes	Editing a progress note always failed (500); no error shown
C2	High	Progress notes	Deleting a progress note always failed (500)
C3	Critical	Progress notes	A note could be posted under another staff member's name
C4	High	Food & fluid	A custom fluid volume could not be typed ('Expected number, received nan')
C5	High	Food & fluid	A fluid entry saved without a volume was counted as food
C6	Medium	Food & fluid	Editing a diet wiped the chef notification / chef name
C7	High	Food & fluid	A diet saved without consistency levels could never be edited (Update did nothing)
C8	Low	Food & fluid	'This Month' on the food & fluid records page always showed 0
C9	Medium	Records	Report dates shown a day early on devices ahead of UK time (food & fluid, continence)
C10	High	Vital signs	Non-numeric or impossible vital values were saved (e.g. temperature 'abc')

ID	Severity	Area	Bug
C11	High	Vital signs	Blood pressure could be saved without a diastolic value
C12	High	Weight	Negative or implausible weights were saved (-5 kg, 900 kg)
C13	High	Appointments	Appointment times were stored in the device's time zone (2:30 PM saved as 10:00 UK on an India-time device)
C14	High	Daily care	Personal care (and continence, dependency, choking and falls forms) time-stamped with the device clock
C15	High	MDT notes	No way to open 'Add Team Member', so residents without a GP on file had no one to attribute a note to
C16	Low	Lifestyle & social	A missing activity name was only rejected on the last step, with no visible error
C17	Low	Care file	Upload presets (GP input / SALT / Dietitian) were overwritten by the file's own name
C18	Low	Care file	Care file v1 folder misspelled 'Depenency'
D · Remaining features (medication, incidents, handover, audits, staff)			
D1	High	Medication	A nurse could pick themselves (or the owner) as the witness for their own dose
D2	Medium	Medication	The 'prepared' time on a dose was shown in UTC (an hour behind during British Summer Time)
D3	High	Incidents	Dates picked in the incident report (incident, date of birth, admission, completed) were saved a day early
D4	High	Residents	Add Resident saved the picked date of birth and admission date a day early
D5	High	Hospital passport	A hospital passport could be generated with every required (*) field blank
D6	Medium	Hospital passport	The default transfer time and last-medication time were UTC, not UK time
D7	Medium	Handover	Handover deletes did nothing: archived notes were never cleared and 'Overwrite?' created duplicate reports
D8	Medium	Handover	A shift note could carry over to the other shift (or overwrite it) after switching shift or date
D9	Low	Action plans	An action plan due today was shown as overdue
D10	Medium	Action plans	Staff of other care homes could be assigned a care home's action plan, and received its status notifications
D11	High	API	Any signed-in user could resolve photo-refresh alerts for any resident, including another organisation's
D12	High	Staff	Staff training records were never saved (lost on reload, although the page said 'added successfully')
D13	Medium	Care homes	The database lets managers create care homes and rename their own, although Settings > Care home is owner-only (<i>Open</i>)

Follow-ups and decisions for the team

- Decide on the open item D13: which care-home fields managers may change (the agency link code needs manager access). D12 is now fixed; confirm the access rule chosen for training records (owners/managers of the care home edit, staff read their own) and whether RQIA inspectors should see them.
- Apply all four new migrations when deploying: `20261005120000_security_hardening.sql`, `20261005150000_resident_record_integrity.sql`, `20261005170000_handover_delete_policies.sql` and

20261005180000_staff_trainings.sql.

- Dates saved with `toISOString().split("T")[0]` remain in about 50 other places. The 47 that compute 'today' are only wrong between midnight and 1 AM UK time in summer; the rest convert a date (care-file assessment dialogs, rota and document date ranges) and should be checked one by one the way D3/D4 were fixed.
- Handover reports saved before D7 may include duplicates for the same shift; the next save of that shift replaces them all. A one-off clean-up query is optional.
- Dead code worth deleting: `.bak/backup` copies of the hospital passport form, the unused `comprehensive-incident-form.tsx` and `report-incident-form.tsx`, and `components/medication/daily/history-columns.tsx` (unused, with the same UTC-time display as D2).
- Manual testing still matters for what the automated suites cannot judge: layout on tablets/phones, wording and usability, PDF/print output, real email delivery, and production data. See the 'Manual vs automated testing' section.
- NHS number validation (B16): editing an existing resident whose stored NHS number fails the Modulus 11 check now requires correcting it. Consider a one-off report of residents with invalid numbers.
- The `resident-files` storage bucket still accepts any MIME type; only the browser restricts uploads to PDF/images. `components/files/UploadFileButton.tsx` accepts any file, so restricting the bucket needs checking against that feature first.
- Pages the page sweep only opens (no deeper flow yet): manager audit (CSV import), appointments and notifications read state, quick-info checks, wounds and medications overviews, agency, MDT summary, settings teams/labels/security.

A · Security & data isolation (database / server actions)

Found by the Vitest DB suite (tests/db) against local Supabase. Fixed mainly in supabase/migrations/20261005120000_security_hardening.sql (new RESTRICTIVE RLS policies, a users-table privilege guard and vetted RPCs) and by making Server Actions identify the caller from the session (lib/server-auth.ts).

A1 Critical Tenancy

Fixed

A nurse could move themselves into another organisation and read its residents

How it was caught tests/db/privilege-escalation.test.ts - "CRITICAL BUG: a nurse can move themselves into another organization..."

Fix guard_user_privileged_columns() trigger on public.users blocks self-changes to organization / care home / role (migration section 2).

Manual check

- Sign in as a nurse. In the browser dev tools run a Supabase update on your own users row setting active_organization_id to another organisation's id.
- ✓ the update is rejected and the residents list still only shows your own care home.

A2 Critical Tenancy

Fixed

A care assistant could switch to another care home in the same organisation

How it was caught tests/db/privilege-escalation.test.ts - "a care assistant can switch to another care home..."

Fix Same users-table guard; care-home switching is only allowed for roles that may work across homes.

Manual check

- Sign in as a care assistant and try to change care home from the sidebar switcher.
- ✓ other care homes are not offered / the change is refused.

A3 Critical Sign-up

Fixed

A brand-new self sign-up could attach itself to any organisation

How it was caught tests/db/privilege-escalation.test.ts - "a brand-new self-signup can attach itself to any organization..."

Fix Users-table guard plus accept_invitation() RPC: organisation, care home and role now come only from a stored invitation (migration section 3).

Manual check

- Sign up a new account without an invitation.
- ✓ the account has no organisation and cannot see any residents.

A4 Critical Sign-up

Fixed

Agency self sign-up could pick an elevated role via user metadata

How it was caught tests/db/privilege-escalation.test.ts - "agency-flagged self-signup can choose an elevated role..."

Fix Agency self sign-up may only take an agency role; complete_agency_onboarding() RPC assigns it server-side.

Manual check

- Complete agency onboarding from an agency invite link.
- ✓ the account is agency_nurse / agency_care_assistant, never manager or owner.

A5 **High** Roles

Fixed

A manager could promote a colleague to owner (above their own level)

How it was caught tests/db/privilege-escalation.test.ts - "a manager can promote a colleague to owner"

Fix user_role_rank() check in the users guard: you cannot grant a role above your own.

Manual check

- As a manager, open Settings > Members and try to change a member's role to Owner.

✓ refused.

A6 **High** Roles

Fixed

Kitchen staff could read clinical records (medications, DNACPR, notes)

How it was caught tests/db/role-scope.test.ts - "kitchen staff cannot read clinical records"

Fix RESTRICTIVE role policies per clinical table (migration section 6); diet data and notifications stay readable for the kitchen portal.

Manual check

- Sign in as kitchen staff.

✓ only the Kitchen Portal is available; diet changes are visible, medication/notes are not.

A7 **High** Rota

Fixed

A nurse could self-approve as 'manager approved nurse' to gain rota management

How it was caught tests/db/role-scope.test.ts - "a nurse cannot self-approve..."

Fix is_manager_approved_nurse is a privileged column in the users guard.

Manual check

- As a nurse, confirm the rota management controls are not available until a manager approves you.

A8 **Critical** Rota

Fixed

Managers could create / manage rotas and temporary staff for another organisation's team

How it was caught tests/db/role-scope.test.ts and tests/db/server-actions.test.ts - rota scope tests

Fix Rota RLS scoped to the caller's organisation (migration section 4); every rota Server Action calls requireActor() + assertTeamInScope() (app/actions/rota.ts).

Manual check

- As a manager, build and publish a weekly rota for your own unit.

✓ works. Rotas of other organisations never appear.

A9 **Critical** Server actions

Fixed

Anonymous callers could invoke Server Actions by passing someone else's actorId

How it was caught tests/db/server-actions.test.ts - "anonymous caller impersonating a manager cannot change contracted hours", "...cannot regenerate a care home's agency link code"

Fix lib/server-auth.ts: the caller is read from the Supabase session cookie; actorId arguments are cross-checked, never trusted.

Manual check

- As a manager, change a staff member's contracted hours on the Staff page.

✓ saves. Signed out, the same action fails.

A10 High Staff

Fixed

Cross-organisation staff changes (approve rota manager, toggle RQIA login)

How it was caught tests/db/server-actions.test.ts - "a manager of org A cannot approve a nurse of org B", "code review #6"

Fix assertUserInScope() in the actions; deactivating an account also bans it at the auth layer.

Manual check
‣ Deactivate an RQIA user in your organisation, then try to sign in as them.
✓ sign-in is refused with a 'deactivated' message.

A11 Critical Email

Fixed

Anonymous callers could send email from care@careo.uk; invite HTML was injectable

How it was caught tests/db/server-actions.test.ts - "anonymous caller cannot send an email...", "invitation HTML escapes caller-controlled fields", "email query parameter ... URL-encoded"

Fix app/actions/invitations.ts and agency-onboarding.ts load the stored invitation, check the sender, escape HTML (lib/html.ts) and URL-encode the link.

Manual check
‣ Invite a member whose care home name contains bold.
✓ the email shows the text literally and the link opens the invitation.

A12 Critical Tenancy

Fixed

Tenant isolation gaps on data tables (cross-organisation SELECT / UPDATE / DELETE)

How it was caught tests/db/tenant-isolation.test.ts - seeds one row in every tenant table and checks each role in org A against org B

Fix zz_scope_care_home RESTRICTIVE policy on every tenant table (migration section 6).

Manual check
‣ Open a resident URL from another organisation (copy an id).
✓ 'Resident not found'.

A13 High Tenancy

Fixed

Non-owner staff in care home A1 could read records of care home A2 in the same organisation

How it was caught tests/db/tenant-isolation.test.ts - "non-owner A1 roles cannot SELECT A2 rows"

Fix can_access_resident / can_access_care_home helpers scope by active care home unless owner (migration section 1).

Manual check
‣ As a nurse in one care home, check the residents list.
✓ only that care home's residents.

A14 Medium Kitchen

Fixed

Diet notifications: sent on no-op saves, and visible to other care homes' kitchens

How it was caught tests/db/triggers.test.ts - two diet notification tests; tests/e2e/smoke.spec.ts kitchen bell flow

Fix Update trigger fires only when a diet field changes (migration section 7); bell filtered to the kitchen's care home; 'mark all read' only marks diet items.

Manual check
‣ Change a resident's diet, then sign in as kitchen staff.
✓ one diet notification; saving the diet again unchanged creates none.

External visitor login logs were visible across organisations

How it was caught tests/db/role-scope.test.ts - "BUG: rqia_login_logs / mdt_login_logs of another organization are hidden" (code-review finding #5)

Fix Same-organisation / care-home scoping on external login logs (migration section 5).

Manual check

- As a nurse, open the RQIA/MDT visit log.
- ✓ only visits to your care home.

B · Application flows (end-to-end and unit tests)

Found by the Playwright journeys/smoke/API specs (tests/e2e) and the Vitest unit suite (tests/unit).

B1 High Auth

Fixed

Anonymous visitors were not redirected away from /settings pages

How it was caught tests/e2e/journeys.spec.ts - "BUG: anonymous visitor is not redirected away from /settings pages"

Fix middleware.ts: /settings added to the protected path prefixes.

Manual check

- Sign out and open /settings/members.
- ✓ redirected to /login.

B2 Medium Auth

Fixed

Kitchen staff could reach blocked pages via browser Back

How it was caught tests/e2e/journeys.spec.ts - "BUG (code review #7): kitchen staff can reach blocked pages via browser back navigation"

Fix middleware.ts redirects kitchen_staff to /dashboard/kitchen-portal for any other /dashboard path; the dashboard layout no longer renders a blocked page while the redirect is pending (fixed in this session).

Manual check

- Sign in as kitchen staff, type /dashboard/residents in the address bar, then press Back.
- ✓ you stay on the Kitchen Portal; the residents page never appears.

B3 Low Accessibility

Fixed

Login form labels were not associated with their inputs

How it was caught tests/e2e/journeys.spec.ts - "BUG (a11y): login form labels are associated with their inputs"

Fix components/auth/forms/LoginForm.tsx: removed the hard-coded ids that broke the label/input link.

Manual check

- On /login click the 'Email' label.
- ✓ the email box gets focus.

B4 High API

Fixed

PDF API routes produced resident documents without a session

How it was caught tests/e2e/api-auth.spec.ts - every non-public API route must return 401 without a session
Fix app/api/pdf/{admission,care-plan,dnacpr,pre-admission}/route.ts call getRequestUserId() (lib/api-auth.ts) and return 401 when signed out.

Manual check

- Signed out, open /api/pdf/admission in the browser.
- ✓ 401 Unauthorized.

B5 High Invitations

Fixed

Accepting an invitation / agency onboarding wrote role and organisation from the browser

- How it was caught tests/e2e/smoke.spec.ts - owner/manager invitation and onboarding journey
- Fix accept_invitation() and complete_agency_onboarding() SECURITY DEFINER RPCs validate token, email and expiry and assign everything server-side.
- Manual check
- Invite a manager, sign up through the link and accept.
 - ✓ lands on the dashboard of the inviting care home with the manager role.

B6 Medium Members

Fixed

Removing a member from the organisation failed

- How it was caught tests/e2e/smoke.spec.ts - "manager removes a care assistant from the organization"
- Fix remove_organization_member() RPC (migration section 9) used by app/(settings)/settings/members/page.tsx.
- Manual check
- As a manager, remove a care assistant in Settings > Members.
 - ✓ they disappear from the list and lose access.

B7 Medium Rota

Fixed

Shift swaps listed other teams' shifts and draft rotas

- How it was caught Fixed earlier on this branch; exercised by tests/e2e/smoke.spec.ts "manager builds and publishes a weekly rota"
- Fix app/(dashboard)/dashboard/rota/components/ShiftSwaps.tsx filters by team and published rotas.
- Manual check
- Open Rota > Shift Swaps.
 - ✓ only shifts from your team's published rotas.

B8 Low Onboarding

Fixed

Care home form overwrote the name the user had typed

- How it was caught Fixed earlier on this branch; exercised by tests/e2e/smoke.spec.ts owner onboarding journey
- Fix CareHomeForm only suggests the organisation name when the field is empty.
- Manual check
- During onboarding, type a care home name and wait.
 - ✓ your text is kept.

B9 Medium Audit

Fixed

Action-plan queries failed (400) on tables without assigned_to_email

- How it was caught Fixed earlier on this branch (PostgreSQL 400 on a missing column); exercised by the action-plan pages
- Fix lib/audit-service.ts only filters on assigned_to_email for tables that have it.
- Manual check
- Open Action Plans as a nurse.
 - ✓ assigned plans load with no error.

B10 Medium Medication

Fixed

Nearest medication round did not wrap past midnight (23:50 picked 20:00)

How it was caught tests/unit/date-time.test.ts

Fix lib/date-utils.ts nearest-round calculation wraps across midnight.

Manual check

- Open Medication > Today's Medications just before midnight.

✓ the 00:00 round is selected.

B11 Low Incidents

Fixed

Incident time parsing accepted minutes like 10:99

How it was caught tests/unit/date-time.test.ts

Fix lib/incident-time-utils.ts accepts minutes 00-59 only.

Manual check

- Enter 10:99 as an incident time.

✓ rejected / falls back.

B12 Low Dates

Fixed

'30 days ago' shown as '2 days' (weeks wrapped modulo 4)

How it was caught tests/unit/date-time.test.ts

Fix lib/utils/dateUtils.ts breaks durations down hierarchically.

Manual check

- Look at a record created 30 days ago.

✓ about '4 weeks 2 days'.

B13 Medium Food & fluid

Fixed

Refused drinks (0 ml) counted as intake; 'Cup of tea' not recognised as fluid

How it was caught tests/unit/domain-logic.test.ts

Fix lib/food-fluid-log-classification.ts: a recorded volume is authoritative; keyword match per word.

Manual check

- Log water with 0 ml.

✓ fluid intake total does not increase.

B14 Medium Privacy

Fixed

getAge logged residents' dates of birth to the browser console

How it was caught tests/unit/domain-logic.test.ts

Fix Removed the console.log in lib/utils.ts.

Manual check

- Open the residents list with dev tools open.

✓ no dates of birth in the console.

B15 High Uploads

Fixed

File upload check allowed scripts / HTML / SVG

How it was caught tests/unit/domain-logic.test.ts - file upload security

Fix lib/files/checkFileSecurity.ts uses an allow-list of document and image types.

Manual check

- Try uploading a .html or .exe file in Documents.

✓ rejected.

B16 High Residents

Fixed

Resident form accepted invalid DOB, future DOB, admission before birth, invalid NHS numbers, blank names

How it was caught tests/unit/schemas.test.ts - CreateResidentSchema BUG tests (still failing before this session)

Fix schemas/CreateResidentSchema.ts with lib/validation.ts: real date, not in future, admission >= DOB, NHS number 10 digits with Modulus 11 check, trimmed names. Note: editing a resident whose stored NHS number is invalid now requires correcting it.

Manual check

- ▶ Add Resident with NHS number 9434765918 (bad check digit).
- ✓ 'Enter a valid 10-digit NHS / H&C number'. 943 476 5919 is accepted.
- ▶ Set admission date earlier than date of birth.
- ✓ 'Admission date cannot be before the date of birth'.

B17 High Medication

Fixed

Medication form accepted non-numeric strength, invalid/duplicate times, CD without schedule, negative stock

How it was caught tests/unit/schemas.test.ts - CreateMedicationSchema BUG tests

Fix schemas/medication/CreateMedicationSchema.ts rules, and a new 'Controlled drug schedule' picker in CreateMedicationForm that appears when 'Controlled Medication' is ticked.

Manual check

- ▶ Add Medication > Scheduled. Enter strength 'lots' and press Next.
- ✓ 'Strength must be a number'.
- ▶ Tick Controlled Medication without choosing a schedule.
- ✓ 'Select the controlled drug schedule'.

B18 Medium Auth

Fixed

New password only required 8 characters (policy says capital, number, special)

How it was caught tests/unit/schemas.test.ts

Fix schemas/auth/NewPasswordSchema.ts enforces capital letter, number and special character.

Manual check

- ▶ Reset a password to 'aaaaaaa'.
- ✓ rejected with a clear message.

B19 High Medication

Fixed

Blood sugar accepted text; insulin could be recorded without site or second signature

How it was caught tests/unit/schemas.test.ts - medication record schemas

Fix schemas/residents/medication/bloodMonitoringSchema.ts: numeric 0.5-40 mmol/L; insulin requires site and second signature.

Manual check

- ▶ In the blood monitoring chart enter 'high' or tick insulin without a second signature.
- ✓ validation errors.

B20 Low Residents

Fixed

getAge returned NaN for an invalid date of birth

How it was caught tests/unit/domain-logic.test.ts

Fix getAge returns null; the residents table shows 'Age unknown'.

Manual check

- (Data issue only) A resident with a malformed DOB shows 'Age unknown' instead of 'NaN years old'.

B21 Low Rota

By design

Rota generator allows back-to-back day + night shifts

How it was caught tests/unit/rota-generator.test.ts - originally flagged as a bug (no 11-hour rest between shifts)

Fix Not changed: the care team confirmed back-to-back shifts must be allowed. The test now guards that behaviour ("allows back-to-back day+night shifts"); the generator still prevents overlapping shifts.

Manual check

- Generate a rota with 08:00-20:00 day and 20:00-08:00 night templates.
- ✓ the same person can be given both shifts; never two overlapping shifts.

B22 Medium Auth

Fixed

Login could hang on 'Redirecting...' after a correct password

How it was caught Intermittent failures of login() in the full e2e runs (screenshot stuck on 'Redirecting...'); found while re-running the suite in this session

Fix app/(auth)/login/page.tsx raced LoginForm: both called router.push (to /onboarding and /dashboard) when the new session appeared. The page now only redirects visitors who were already signed in on arrival, and sends onboarded users to /dashboard.

Manual check

- Sign in 10 times in a row (sign out between).
- ✓ every time you land on the dashboard within a couple of seconds.
- While signed in, open /login.
- ✓ redirected to the dashboard (not onboarding).

C · Resident profile (Playwright suite)

Found by the new resident-profile specs (tests/e2e/resident-*.spec.ts), which drive each profile feature in a real browser and check what was saved in the database.

C1 High Progress notes

Fixed

Editing a progress note always failed (500); no error shown

How it was caught tests/e2e/resident-clinical.spec.ts - "BUG: editing a progress note fails (PATCH ... returns 500)"

Fix app/api/progress-notes/[id]/route.ts copied NextResponse.next() headers into the reply, which Next.js rejects in route handlers. Plain JSON responses now.

Manual check

- Resident > Progress Notes > : > Edit Note, change the text, Update Note.
- ✓ 'Progress note updated successfully' and the new text shows.

C2 High Progress notes

Fixed

Deleting a progress note always failed (500)

How it was caught tests/e2e/resident-clinical.spec.ts - "BUG: deleting a progress note fails"

Fix Same route fix as C1.

Manual check

- : > Delete Note > confirm.
- ✓ 'Progress note deleted successfully' and the note disappears.

C3 Critical Progress notes

Fixed

A note could be posted under another staff member's name

How it was caught tests/e2e/resident-clinical.spec.ts - "BUG: a progress note cannot be posted under another staff member's name" and "progress notes (database guard)"

Fix POST /api/progress-notes takes the author from the session; new trigger enforce_progress_note_author (migration 20261005150000) sets author on insert and keeps it on edit for any direct DB write.

Manual check

- Add a progress note.
- ✓ the author shown is you. Editing a colleague's note keeps their name as author.

C4 High Food & fluid

Fixed

A custom fluid volume could not be typed ('Expected number, received nan')

How it was caught tests/e2e/resident-food-fluid.spec.ts - "BUG: a custom fluid volume cannot be typed"

Fix The volume Select only ever holds a real item (a preset or 'custom'); custom mode is tracked explicitly so typing 2500 doesn't hide the box at 250.

Manual check

- Food & Fluid > Log Fluid Entry > type 120 in 'Enter custom amount in ml'. Save.
- ✓ saved; Fluid tab shows 'Volume: 120ml'. 2500 is blocked (max 2000).

C5 **High** Food & fluid

Fixed

A fluid entry saved without a volume was counted as food

How it was caught tests/e2e/resident-food-fluid.spec.ts - "BUG: a fluid entry saved without a volume is counted as a food entry"

Fix Fluid entries require a volume ('Volume is required for fluid entries').

Manual check

- ▶ Log Fluid Entry with a drink name but no volume. Save.
- ✓ validation error; Food Entries count unchanged.

C6 **Medium** Food & fluid

Fixed

Editing a diet wiped the chef notification / chef name

How it was caught tests/e2e/resident-food-fluid.spec.ts - "BUG: re-saving an existing diet keeps the chef notification and name"

Fix Edit form is prefilled from the camelCase fields it was loaded into (chefNotified / chefName).

Manual check

- ▶ Save a diet with Chef Notified = Yes and a name. Edit Diet > Next > Next.
- ✓ Yes is selected and the chef name is filled; after Update the badge still shows the name.

C7 **High** Food & fluid

Fixed

A diet saved without consistency levels could never be edited (Update did nothing)

How it was caught tests/e2e/resident-food-fluid.spec.ts - "BUG: a diet saved without consistency levels can be edited again" (found while fixing C6)

Fix NULL columns are loaded as undefined (the form's optional enums rejected null); invalid submits now show an error toast.

Manual check

- ▶ Save a diet without food/fluid consistency. Edit it, add Vegetarian, Update.
- ✓ 'Diet information updated successfully'.

C8 **Low** Food & fluid

Fixed

'This Month' on the food & fluid records page always showed 0

How it was caught tests/e2e/resident-food-fluid.spec.ts - "BUG: 'This Month' stat ... ignores reports from this month"

Fix Counted with get_paginated_food_fluid_dates for the current UK month instead of a placeholder.

Manual check

- ▶ Log an entry today, open See All Records.
- ✓ This Month = 1.

C9 **Medium** Records

Fixed

Report dates shown a day early on devices ahead of UK time (food & fluid, continence)

How it was caught tests/e2e/resident-food-fluid.spec.ts - "BUG: report dates are shown a day early..." (browser set to Asia/Kolkata)

Fix Date-only values are formatted as calendar dates (parseISO) instead of device-local midnight converted to UK time.

Manual check

- ▶ Set the computer's time zone to e.g. India, log an entry, open See All Records.
- ✓ today's UK date.

C10 High Vital signs

Fixed

Non-numeric or impossible vital values were saved (e.g. temperature 'abc')

How it was caught tests/e2e/resident-clinical.spec.ts - "BUG: non-numeric or impossible vital values are accepted"

Fix health-monitoring schema checks numbers and plausible ranges (temp 30-45 °C, HR 20-250, RR 4-60, SpO2 50-100).

Manual check ▶ Health & Monitoring > Record Vital > Temperature 'abc' or 95.
✓ validation error, nothing saved.

C11 High Vital signs

Fixed

Blood pressure could be saved without a diastolic value

How it was caught tests/e2e/resident-clinical.spec.ts - "BUG: blood pressure can be saved without a diastolic value"

Fix Systolic 50-260 and diastolic 20-160 both required.

Manual check ▶ Record Vital > Blood Pressure > Systolic 130 only.
✓ 'Diastolic is required'.

C12 High Weight

Fixed

Negative or implausible weights were saved (-5 kg, 900 kg)

How it was caught tests/e2e/resident-clinical.spec.ts - "BUG: negative or implausible weights are accepted"

Fix WeightChart rejects weights outside 20-300 kg (or lb equivalent); DB CHECK constraint weight_records_weight_kg_range (NOT VALID, so old rows stay readable).

Manual check ▶ Weight > Record > -5.
✓ 'Weight must be between 20 and 300 kg'.

C13 High Appointments

Fixed

Appointment times were stored in the device's time zone (2:30 PM saved as 10:00 UK on an India-time device)

How it was caught tests/e2e/resident-care-records.spec.ts - "BUG: appointment time is stored in the device timezone"

Fix components/ui/date-time-picker.tsx treats the picked date/time as Europe/London and displays stored times in UK time.

Manual check ▶ Set the computer to another time zone; create an appointment at 2:30 PM.
✓ it shows and is stored as 14:30 UK time.

C14 High Daily care

Fixed

Personal care (and continence, dependency, choking and falls forms) time-stamped with the device clock

How it was caught tests/e2e/resident-care-records.spec.ts - "BUG: personal care is time-stamped with the device clock instead of UK time"

Fix New getCurrentUKTime() in lib/date-utils.ts replaces new Date().toString() defaults; assessment dates use getUKTodayDate().

Manual check ▶ On a non-UK time zone, Log Personal Care now.
✓ the log shows the current UK time.

C15 High MDT notes

Fixed

No way to open 'Add Team Member', so residents without a GP on file had no one to attribute a note to

How it was caught tests/e2e/resident-care-records.spec.ts - "BUG: there is no way to open the 'Add Team Member' dialog"

Fix '+ Add Team Member' button next to the Team Member field in Create Note.

Manual check ▶ Multi Disciplinary Note > Create Note > Add Team Member. Add a physiotherapist.
✓ they appear in the Team Member list.

C16 Low Lifestyle & social

Fixed

A missing activity name was only rejected on the last step, with no visible error

How it was caught tests/e2e/resident-care-records.spec.ts - "BUG: a missing activity name is only rejected on the last step"

Fix 'Next' validates step 1; an invalid final submit shows a toast and returns to step 1.

Manual check ▶ Record Activity > Next without a name.
✓ 'Activity name is required' on step 1.

C17 Low Care file

Fixed

Upload presets (GP input / SALT / Dietitian) were overwritten by the file's own name

How it was caught tests/e2e/resident-care-file.spec.ts - "BUG: nutrition folder upload presets ... are overwritten"

Fix UploadFileModal keeps the preset name and resyncs it each time it opens.

Manual check ▶ Care File > Nutrition and Hydration > Documents + > SALT > choose any PDF.
✓ File Name stays 'SALT'.

C18 Low Care file

Fixed

Care file v1 folder misspelled 'Depenency'

How it was caught tests/e2e/resident-care-file.spec.ts - "BUG: v1 dependency folder name is misspelled"

Fix config.ts label fixed; migration renames existing files' folder_name. v1 and v2 'Dependency' folders now share uploads.

Manual check ▶ Open the v1 Care File.
✓ '5. Dependency'.

D · Remaining features (medication, incidents, handover, audits, staff)

Found by the specs added in the last pass: tests/e2e/medication-flows, incident-flows, hospital-passport, handover, action-plans, careo-audit, staff, settings, resident-dates, page-sweep and new cases in api-auth.spec.ts and tests/db/role-scope.test.ts. Open items are kept as expected-failure tests (test.fail / it.fails), so the suites stay green and flag when the behaviour changes.

D1 High Medication

Fixed

A nurse could pick themselves (or the owner) as the witness for their own dose

- How it was caught** tests/e2e/medication-flows.spec.ts - "BUG: neither the administering nurse nor the owner can be picked as witness"; tests/unit/witness.test.ts
- Fix** lib/medication/witness.ts (isEligibleWitness) leaves the signed-in user and the organisation owner out of every witness picker: the medication round, the PRN/topical administer dialogs and the eMAR administration modal. Marking a dose taken with yourself as witness is refused.
- Manual check**
- Medication > Today's Medications: prepare a dose and open 'Select witness'.
 - ✓ neither your own name nor the owner is offered. The same applies in the PRN/topical 'Administer' dialog and the eMAR modal.

D2 Medium Medication

Fixed

The 'prepared' time on a dose was shown in UTC (an hour behind during British Summer Time)

- How it was caught** tests/e2e/medication-flows.spec.ts - "BUG: the prepared time is shown in UK time, not UTC"
- Fix** columns.tsx formats the prepared/administered time in Europe/London.
- Manual check**
- Between March and October, prepare a dose at a known time.
 - ✓ the time shown under the tick is the current UK time.

D3 High Incidents

Fixed

Dates picked in the incident report (incident, date of birth, admission, completed) were saved a day early

- How it was caught** tests/e2e/incident-flows.spec.ts - "BUG: a date picked in the calendar is saved as the day before" (browser in Asia/Kolkata; the same happens on UK devices during BST)
- Fix** simple-incident-form.tsx saves calendar dates with formatDateToLocal() instead of toISOString(), and loads stored dates with parseISO().
- Manual check**
- Between March and October, create an incident and pick the 1st of the month as the incident date.
 - ✓ the saved report and the PDF show the 1st, not the last day of the previous month.

D4 High Residents

Fixed

Add Resident saved the picked date of birth and admission date a day early

- How it was caught** tests/e2e/resident-dates.spec.ts - "BUG: picked date of birth and admission date are kept, not shifted a day early"
- Fix** CreateResidentForm.tsx stores the picked calendar day with formatDateToLocal() and displays it with parseISO().
- Manual check**
- Add Resident > Date of Birth > pick 17 May 1990.
 - ✓ the button shows 17/05/1990 and the resident's profile shows 17 May 1990.

D5 **High** Hospital passport

Fixed

A hospital passport could be generated with every required (*) field blank

- How it was caught** tests/e2e/hospital-passport.spec.ts - "BUG: a passport with the required (*) fields left blank cannot be generated"
- Fix** hospital-transfer/types.ts requires every field the form marks with * (hospital, next of kin, GP, SBAR, past medical history, skin state, medication regime, sign-off); an invalid submit shows 'Please complete the required fields marked *'.
- Manual check**
- Hospital Transfer > Create Passport > Generate Passport without filling anything in.
 - ✓ the toast and inline 'Required' messages; no passport is saved.

D6 **Medium** Hospital passport

Fixed

The default transfer time and last-medication time were UTC, not UK time

- How it was caught** tests/e2e/hospital-passport.spec.ts - "BUG: the default transfer and last-medication times are UK time, not UTC"
- Fix** lib/hospital-passport-prefill.ts defaults both to the current Europe/London time.
- Manual check**
- Between March and October, open Create Passport.
 - ✓ 'Date and Time of Transfer' shows the current UK time, not an hour earlier.

D7 **Medium** Handover

Fixed

Handover deletes did nothing: archived notes were never cleared and 'Overwrite?' created duplicate reports

- How it was caught** tests/e2e/handover.spec.ts - "Save Handover archives the shift ... and clears the live sheet" and "BUG: saving the same shift twice overwrites the report instead of duplicating it"
- Fix** New migration 20261005170000_handover_delete_policies.sql adds the missing DELETE policies on handover_comments and handover_reports; the save replaces every existing report for the shift (cleaning up earlier duplicates) and reports delete errors.
- Manual check**
- Handover: type a shift note, Save Handover, then Save Handover again for the same shift and confirm the overwrite.
 - ✓ All Handovers lists one report for that shift, and the live sheet's notes are empty after saving.

D8 **Medium** Handover

Fixed

A shift note could carry over to the other shift (or overwrite it) after switching shift or date

- How it was caught** tests/e2e/handover.spec.ts - "BUG: switching to the other shift does not carry over or overwrite this shift's note" (failed intermittently in a full run)
- Fix** handover-sheet-view.tsx keys each notes cell by resident, date and shift, so every shift starts with its own note state.
- Manual check**
- Type a note on Day Shift, switch to Night Shift.
 - ✓ the night note is empty; typing there leaves the day note unchanged.

D9 Low Action plans

Fixed

An action plan due today was shown as overdue

- How it was caught tests/e2e/action-plans.spec.ts - "BUG: a plan due today is not shown as overdue"
- Fix action-plans/page.tsx treats the due date as a calendar day: overdue only once that day has ended.
- Manual check
- Create an action plan due today.
 - ✓ no red overdue marker until tomorrow.

D10 Medium Action plans

Fixed

Staff of other care homes could be assigned a care home's action plan, and received its status notifications

- How it was caught tests/e2e/action-plans.spec.ts - "BUG: a care home's action plan cannot be assigned to staff of another care home"
- Fix auditService.getOrganizationMembers() now filters by organisation (its argument was ignored) and optionally by care home; the action-plans page passes the active care home.
- Manual check
- As a manager of one care home, Action Plans > Add action plan > Assign To.
 - ✓ only staff of your care home (owner excluded) are listed.

D11 High API

Fixed

Any signed-in user could resolve photo-refresh alerts for any resident, including another organisation's

- How it was caught tests/e2e/api-auth.spec.ts - "BUG: org A nurse cannot resolve photo-refresh alerts of an org B resident"
- Fix app/api/alerts/resolve-photo-refresh/route.ts checks the caller can see the resident (under RLS) before the service-role update; otherwise 404.
- Manual check
- Signed in, POST /api/alerts/resolve-photo-refresh with another organisation's residentId.
 - ✓ 404 and the alert stays open. Updating your own resident's photo still clears the alert.

D12 High Staff

Fixed

Staff training records were never saved (lost on reload, although the page said 'added successfully')

- How it was caught tests/e2e/staff.spec.ts - "BUG: a training record survives a page reload"
- Fix New table staff_trainings (migration 20261005180000_staff_trainings.sql). The Trainings page loads and saves records there; organisation and care home are taken from the staff member by a trigger. Owners/managers of the staff member's care home can read and write; staff can read their own. A completed training past its expiry date shows as Expired. Access is covered by tests/db/role-scope.test.ts "staff training records".
- Manual check
- Staff > a staff member > Trainings > Add Training, then reload.
 - ✓ the training is still listed. A nurse or care assistant cannot add trainings.

The database lets managers create care homes and rename their own, although Settings > Care home is owner-only

How it was caught tests/db/role-scope.test.ts - "BUG (open): a manager cannot create care homes" / "... cannot rename the care home" (marked it.fails). Deleting another care home is already blocked.

Fix Not fixed. The policy "Owners and Managers manage care homes" grants managers ALL operations on care homes in their organisation (deleting another home is blocked by the scope policy). The agency link code is written with the service role (app/actions/agency-onboarding.ts), so restricting care_homes INSERT/UPDATE to owners would not break it; needs a decision on whether managers should rename their home.

Manual check

- As a manager, in dev tools run a Supabase insert into care_homes for your organisation.

✓ Expected (today): it succeeds. After the fix it should be refused.